→ Authentication (vs) Authorization

↓

Identify the user.

masaischool.com

↳ To access this website no authentication is required.

→ Register for a course.

↳ Authentication is must.

↓

Who is the user.

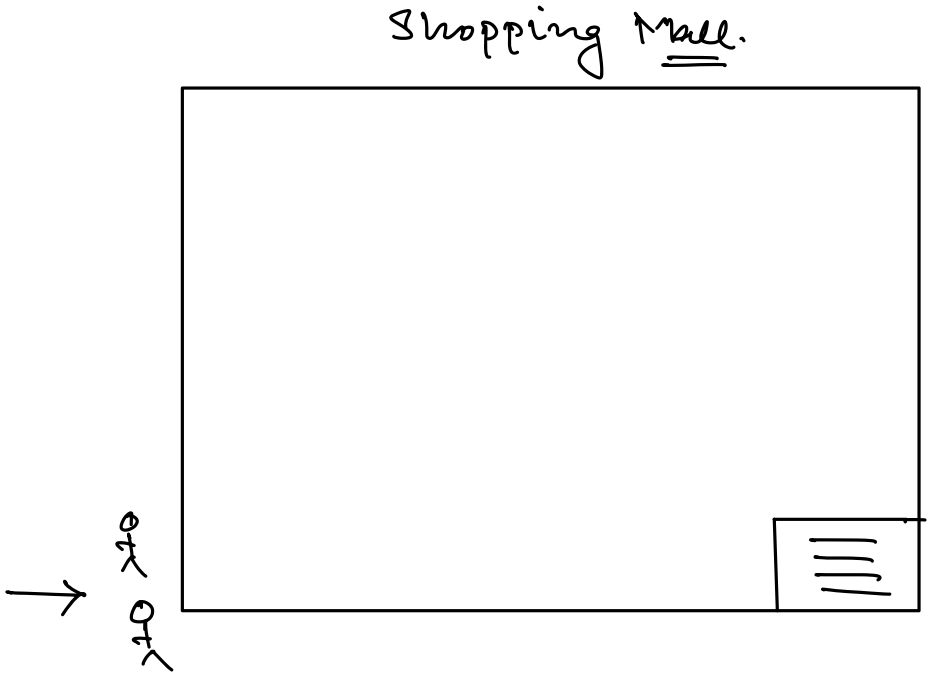
↳ Proof of Identity.

→ Email + password / otp

→ Phone + otp / password

Authorization.

↳ What the user is trying to access.



RBAC.

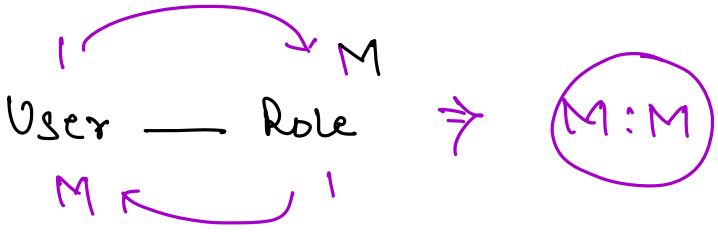
↳ Role Based Access Control.

users

id	name	email	pass

roles

id	name
1	Student
2	Instructor
3	TA
4	Admin



users_roles

user_id	role_id

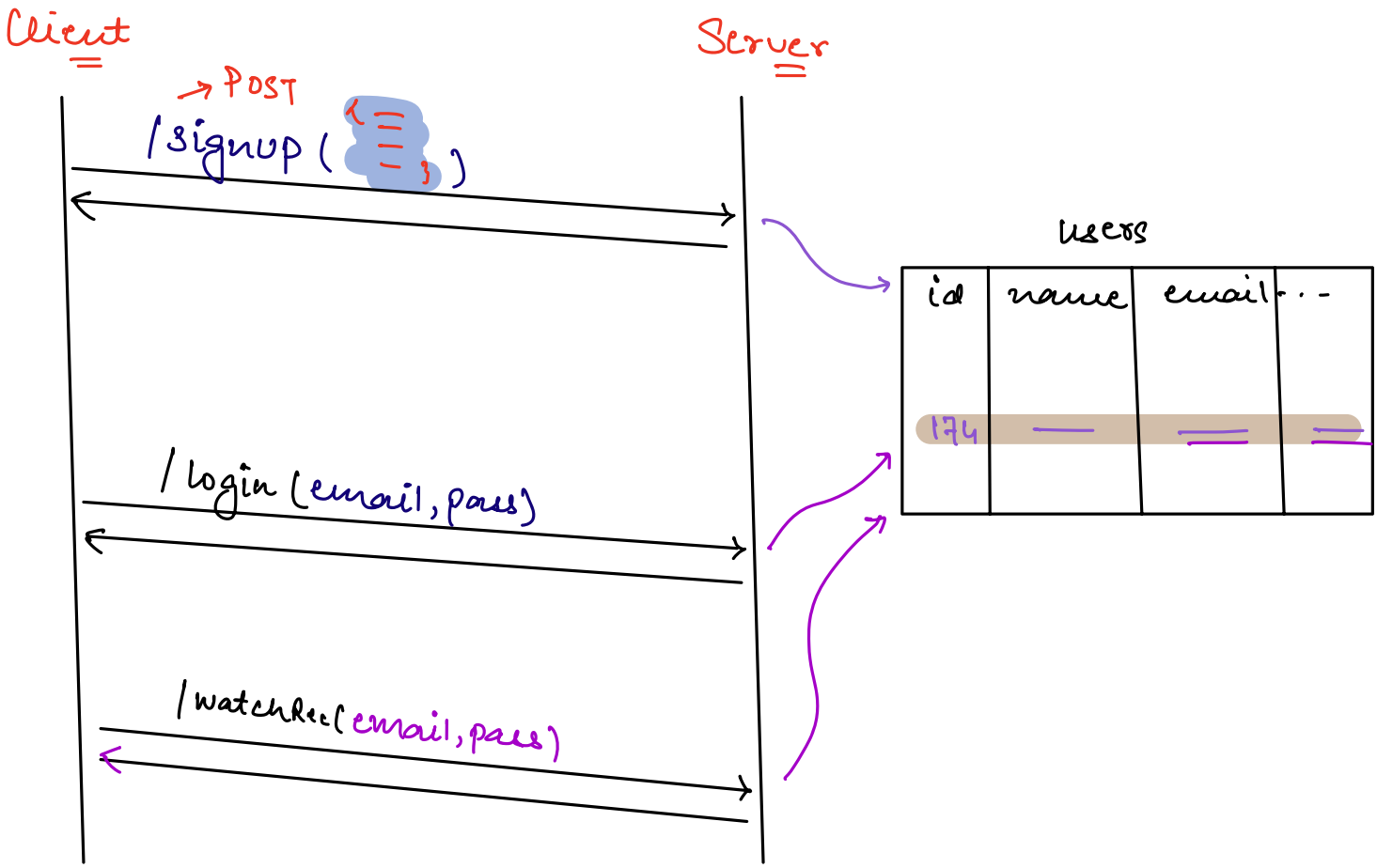
masaischool.com/admin

→ If user is NOT authorized then server returns 401 http status.

↓

UnAuthorized

SignUp & login flow

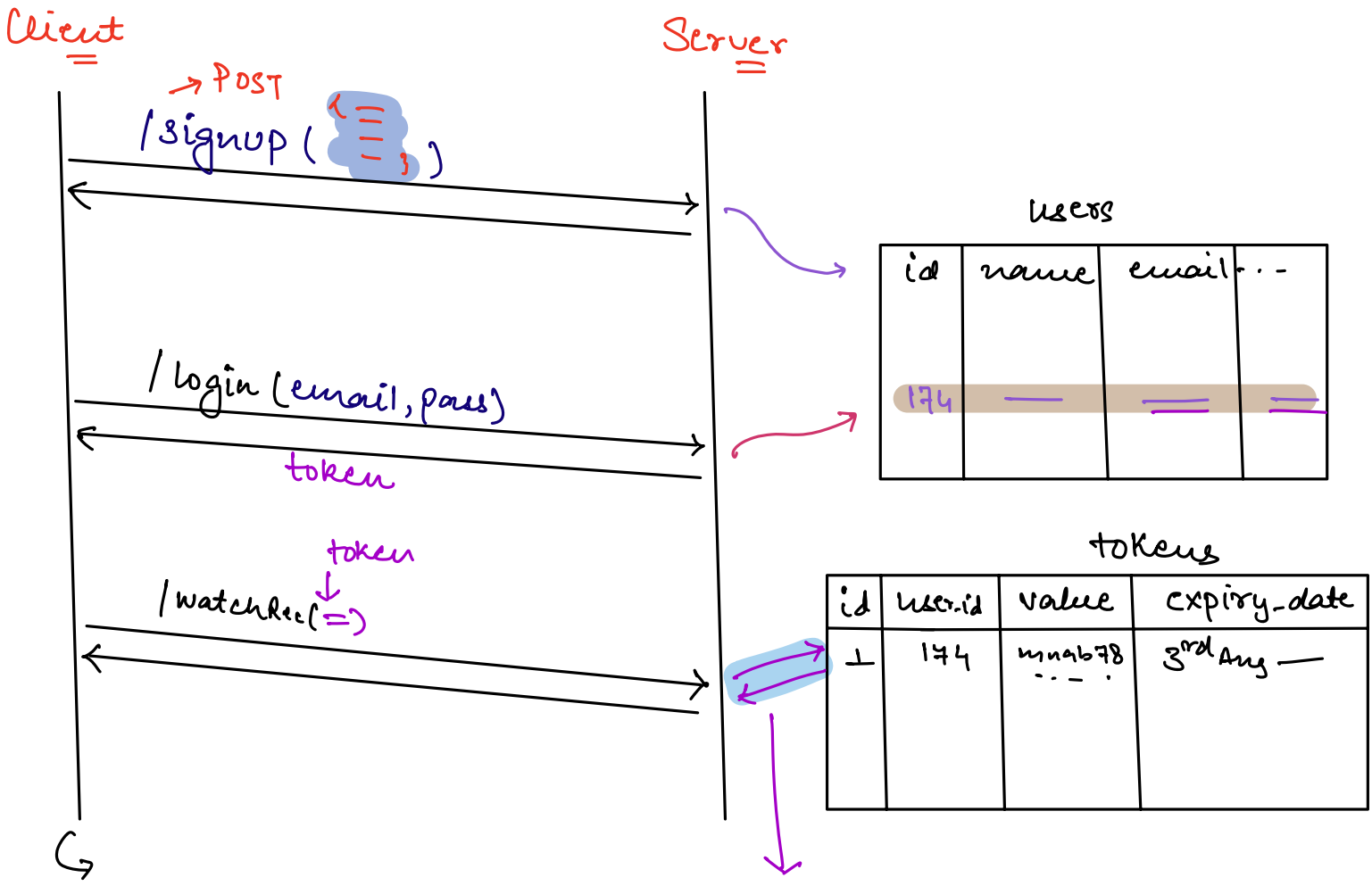


⇒ HTTP protocol is Stateless.

⇒ Every HTTP request is independent.

⇒ Every HTTP request should be self-sufficient

TOKEN.



Amazon.in : ——

masaischool.com —

fb.com : ——

—— : ——

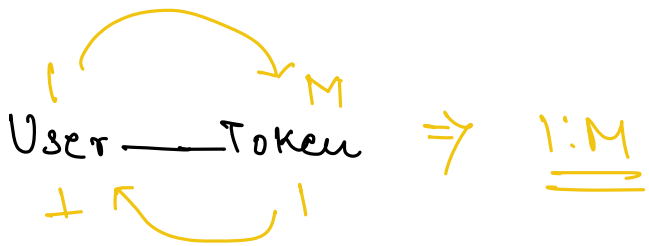
—— : ——

for every token validation, we are making a DB call (n/w call) which is expensive.

JWT

↓

Self-Validating Tokens.



How to store passwords in DB ?

users

id	name	email	password
—	—	—	abcd
—	—	—	1234
—	—	—	admin

→ Password shouldn't be stored in the raw format in the DB.

→ Encryption

raw password —(secret key + encryption Algo)→ encrypted password.

users

id	name	email	password
—	—	—	x$@!12794Babxy
—	—	—	
—	—	—	

→ Hashing

hash (x) ↓

3

abcd

users

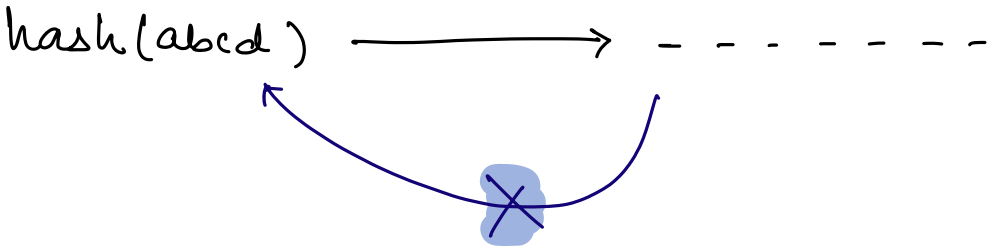
id	name	email	password
—	—	—	x$@!127948a6xy → hashed password.
—	—	—	—
—	—	—	x$@!127948a6xy
			—
			x$@!127948a6xy

abcd

abcd → hash() ⇒ ——

abcd

abcd



users

id	name	email	password
—	—	—	x$@!12794Ba6xy
—	—	—	—
—	—	—	x$@!12794Ba6xy
			—
			x$@!12794Ba6xy
—	—	hacker@—	x$@!12794Ba6xy

⇒ Hashing + Salting

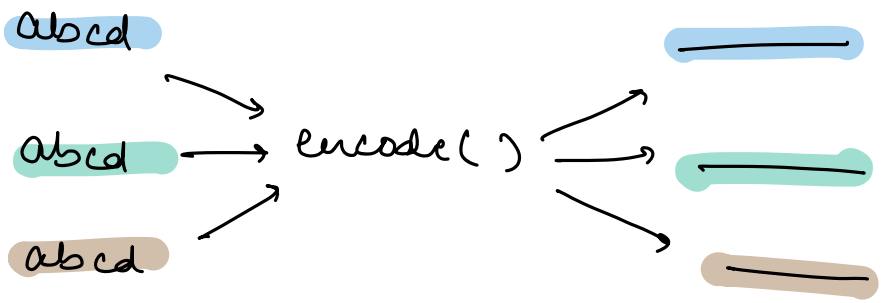
↳ Randomness.

fun(x) {

hash(x + Salting)

}

BCrypt Password Encoder:
- encode(x) ⇒ ——
- Verify(—, —)



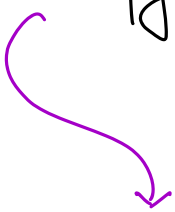
users

id	name	email	password
—	—	—	x$@!127948a6xy
—	—	—	——
—	—	—	mn?$#<xy7178KL— .
			——

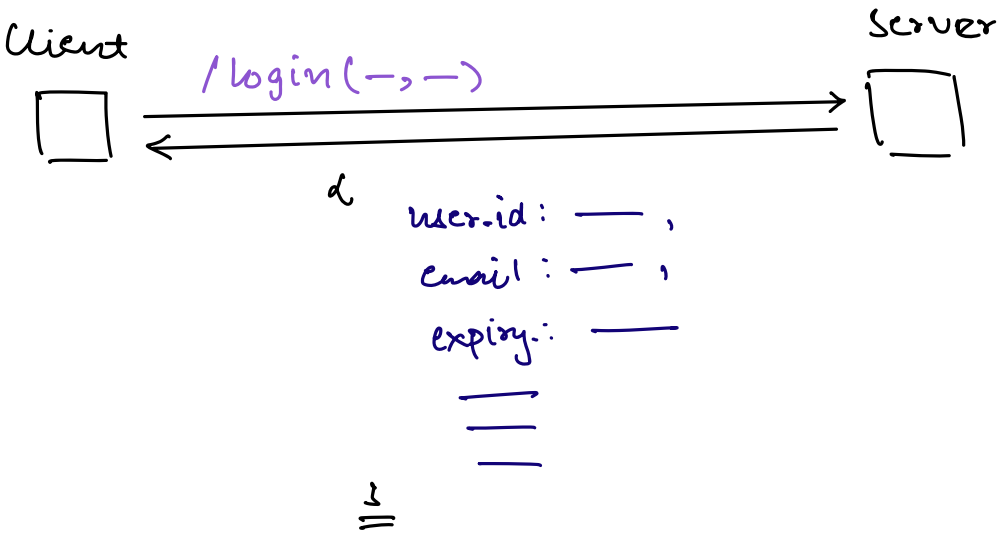
/login(email, raw-password)

encode()

Verify (encoded-password, raw-password)

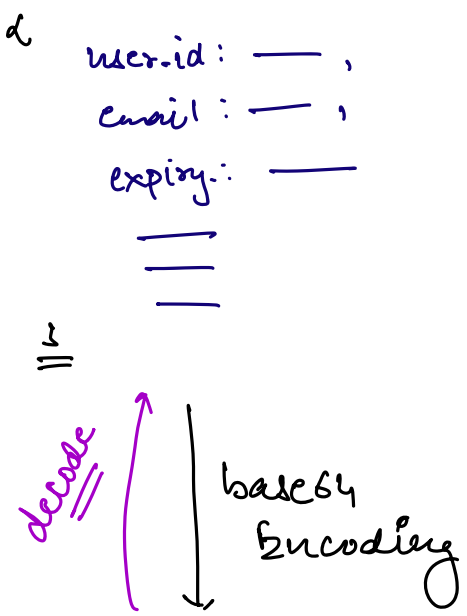


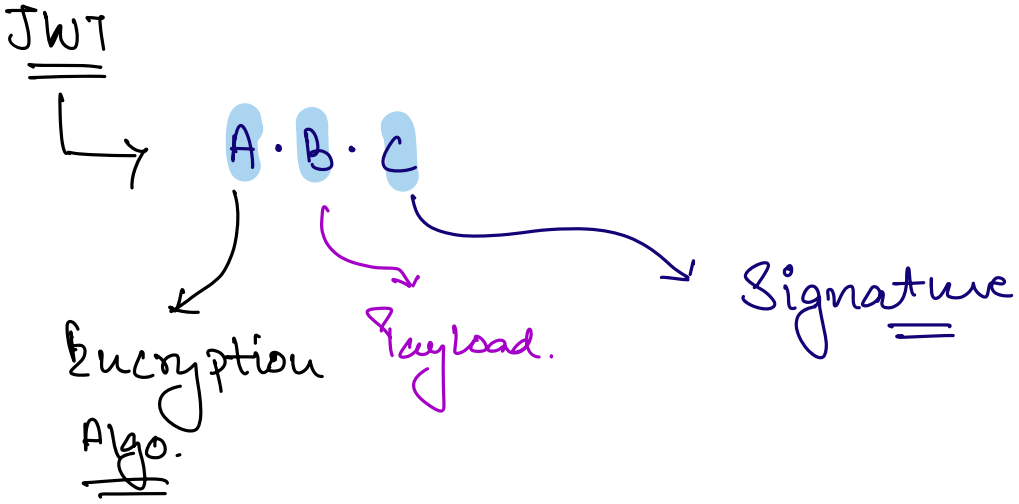
If it is possible to generate the encoded password from the raw-password or not.



JWT

↳ JSON Web Token




JWT
A . B . C
Encryption Algo.
Payload.
Signature